ROYAL HOLLOWAY, UNIVERSITY OF LONDON
BSc/MSci EXAMINATION 2021

IY3660: Applications of Cryptography
IY3660R: Applications of Cryptography – for FIRSTSIT/RESIT CANDIDATES

Time allowed: **TWO hours**

Answer THREE questions
No credit will be given for attempting any further questions

- Handwrite your answers on paper, and write your candidate number and the module number at the top of each page. Photograph/scan the pages and keep the original paper versions, as they may be required by the examiners.
- For each question you attempt, please clearly state the question number.
- Please DO NOT include your name or Student ID anywhere on your work.
- **Academic Misconduct:** We will check all assignments for academic misconduct. Suspected offences will be dealt with under the College's formal Academic Misconduct procedures. Please remember:
  - The work submitted is expected to be your own work and only your work. You may not ask for help from any source, or copy anyone else's work.
  - You must not give help to anyone else, including sending them any parts of the questions or copies of your solutions.
  - You must not discuss the questions or solutions with anyone else.
- **Submitting your work:**
  - Your document must be submitted through Moodle using the submission link in the module Moodle page. If possible please convert your document into a PDF document to make the submission process quicker and easier.
  - Emailed submissions will not be accepted.
  - **You must complete your exam upload within 1 hour of the exam finish time.**

Important Copyright Notice
This exam paper has been made available in electronic form
strictly for the educational benefit of current Royal Holloway students
on the course of study in question.
No further copying, distribution or publication of this exam paper is permitted.
By printing or downloading this exam paper, you are consenting to these restrictions.

Question 1

(a) Give a formal definition of a block cipher. Your answer should make reference to the block size n and the key size k. [4 marks]

(b) What is the security notion that a secure n-bit block cipher is expected to satisfy? Define this security notion in the form of an indistinguishability game, and explain what it is meant by "the block cipher E is secure" under this notion. [4 marks]

(c) Let $\texttt{add_pad}()$ be a padding scheme for bit-oriented block ciphers with n-bit block sizes, defined as follows:

- given a message M as a bit string, add a single $\texttt{1}$ bit at the end of M;
- then, add to the resulting string as many zero bits $\texttt{0}$ as are needed to fill up a complete n-bit block;
- the resulting string is the plaintext $P = \texttt{add_pad}(M)$.

PS: Note that adding the single bit $\texttt{1}$ is *always* required in this padding scheme.

Explain in detail, using a pseudo-code, a typical implementation of a function `remove_pad()` to remove the padding from a plaintext for this padding scheme. Your function should take as input a plaintext P, and output either the message M with the padding stripped, or an error message "padding error" if the padding is invalid in some way.
(Hint: your pseudo-code should work for general block sizes; thus you may use a variable name `blocksize` in your pseudo-code to reflect this, and check whether the input string P has a valid length (for padded strings). Moreover your pseudo-code should also check that the number of padding bits does not exceed the maximum possible value that is implied by there being at most one complete block of padding.) [4 marks]

(d) Let E be a block cipher operating on 4-bit blocks. Let K be a key, such that encryption with E under K is given by the table below:

$0000 \mapsto 1100$	$0100 \mapsto 1001$	$1000 \mapsto 0011$	$1100 \mapsto 0100$
$0001 \mapsto 0101$	$0101 \mapsto 0000$	$1001 \mapsto 1110$	$1101 \mapsto 0111$
$0010 \mapsto 0110$	$0110 \mapsto 1010$	$1010 \mapsto 1111$	$1110 \mapsto 0001$
$0011 \mapsto 1011$	$0111 \mapsto 1101$	$1011 \mapsto 1000$	$1111 \mapsto 0010$

For example, $E_K(\texttt{0000}) = \texttt{1100}$ and $E_K(\texttt{0100}) = \texttt{1001}$. Likewise, decryption of $\texttt{0010}$ is given by $D_K(\texttt{0010}) = E_K^{-1}(\texttt{0010}) = \texttt{1111}$.

No further copying, distribution or publication of this exam paper is permitted.
By printing or downloading this exam paper, you are consenting to these restrictions.

Let $M = \texttt{1100 0010 1100 10}$ be a 14-bit message which we would like to encrypt using the block cipher E under key K.

i. Encrypt the message M with E_K using the ECB mode. If padding is required, use the padding scheme defined in item (c) above. [3 marks]

ii. Explain what the main security limitation of ECB mode is. Illustrate this security issue by showing whether you can make any inference about the message M based solely on the ciphertext C you computed in item (d).i above. [3 marks]

iii. Encrypt the message M with E_K using the CTR mode. As counter, you should use the convention $ctr_0 = \texttt{0000}$, $ctr_1 = \texttt{0001}$, $ctr_2 = \texttt{0010}$, $ctr_3 = \texttt{0011}$, etc. If padding is required, use the padding scheme defined in item (c) above. [4 marks]

(e) The following 20-bit ciphertext is the encryption of a message M with E_K using the CBC mode:

$$\begin{array}{ccccc} C_0(=IV) & C_1 & C_2 & C_3 & C_4 \\ \shortparallel & \shortparallel & \shortparallel & \shortparallel & \shortparallel \\ \texttt{0011} & \texttt{0011} & \texttt{1001} & \texttt{0110} & \texttt{0001} \end{array}$$

The message has been padded using the padding scheme defined in the item (c) above.

i. Decrypt the ciphertext C with CBC to obtain a plaintext P. [6 marks]

ii. Apply the `remove_pad()` function you defined in item (c) above to P to recover the original message M. [2 marks]

iii. Assume Alice sends the ciphertext C to Bob, which an adversary Mallory intercepts. Mallory would like to modify C into a ciphertext C' such that, on decryption of C' by Bob, the first block of the resulting message M' is $\texttt{0001}$. What modification in the ciphertext C should Mallory perform to achieve that? [2 marks]

iv. What other cryptographic mechanism – in addition to CBC encryption – would you suggest that Alice and Bob use to protect their communication against the attack described in item (e).iii above? [2 marks]

No further copying, distribution or publication of this exam paper is permitted.
By printing or downloading this exam paper, you are consenting to these restrictions.

Question 2

(a) What security service is a Message Authentication Code (MAC) intended to provide? [1 marks]

(b) A MAC scheme consists of a pair of algorithms ($\texttt{Tag}$, $\texttt{Vrf}$). Describe the function of each of these algorithms and explain what is meant by the *correctness* of a MAC scheme. [3 marks]

(c) The standard notion of security for a MAC scheme is *existential unforgeability under chosen message attack*, or EUF-CMA security for short. Give a detailed description of this security notion. You may use a diagram to illustrate your answer. [6 marks]

(d) Suppose ($\texttt{Tag}$, $\texttt{Vrf}$) is an EUF-CMA-secure MAC scheme with t-bit authentication tags. Consider the following MAC scheme ($\texttt{Tag}', \texttt{Vrf}'$), producing $(t+1)$-bit tags, defined as follows:

- the $\texttt{Tag}'$ algorithm is given by $\texttt{Tag}'_K(m) := \texttt{Tag}_K(m)||m_0$, where $||$ denotes concatenation of strings, and m_0 denotes the first bit of m;
- the $\texttt{Vrf}'$ algorithm is defined in the obvious way.

Answer the following questions:

i. Provide a brief argument to show that ($\texttt{Tag}$', $\texttt{Vrf}$') is also EUF-CMA-secure. [2 marks]

ii. What can you then conclude about the confidentiality that is provided in general by an EUF-CMA-secure MAC scheme for its input messages m? [2 marks]

(e) An Authenticated Encryption (AE) scheme consists of a triple of algorithms, ($\texttt{KGen}, \texttt{Enc}, \texttt{Dec}$). Describe the function of each of these algorithms and explain what is meant by the *correctness* of an AE scheme. [4 marks]

(f) AE schemes can be built using the *generic composition* of symmetric encryption schemes and MAC schemes. There are three principal methods for doing so, known as EtM, MtE and E&M. Describe each of these three methods. [3 marks]

(g) Consider combining the MAC scheme ($\texttt{Tag}', \texttt{Vrf}'$) defined in item (d) above, with an IND-CPA-secure symmetric encryption scheme in an "E&M" generic construction to obtain an AE scheme. Describe the ciphertexts in this scheme. What can you say about the security offered by this construction? What can you conclude about the generic security of the "E&M" approach to building AE? [4 marks]

No further copying, distribution or publication of this exam paper is permitted.
By printing or downloading this exam paper, you are consenting to these restrictions.

(h) Let H be a n-bit hash function. Consider the following "hash-based" MAC scheme, using n-bit keys K and producing n-bit tags, defined as follows:

- the $\texttt{Tag}$ algorithm is given by $\texttt{Tag}_K(m) := H(m) \oplus K$;
- the $\texttt{Vrf}$ algorithm is defined in the obvious way.

Answer the following questions about this MAC scheme.

i. Show that the MAC scheme is vulnerable to a key recovery attack. State the resources that your attack consumes, in terms of calls to the oracles in the EUF-CMA security definition. [3 marks]

ii. Is the scheme above an EUF-CMA-secure MAC scheme? Justify your answer by either providing an argument for the security of the scheme, or by describing an efficient adversary that can win the UF-CMA security game with high probability. [3 marks]

iii. Provide another example of a "hash-based" MAC scheme, describing how the $\texttt{Tag}$ algorithm is defined. What statement can you make about the security of your MAC scheme example? [3 marks]

No further copying, distribution or publication of this exam paper is permitted.
By printing or downloading this exam paper, you are consenting to these restrictions.

Question 3

(a) The naive RSA-based digital signature scheme produces signatures σ, computed as $\sigma = M^d \bmod N$. Here M is a message interpreted as a number between 0 and $N-1$; d is the signing key sk; (N, e) is the verification key vk; and $N = pq$ is an RSA modulus.

i. Show how signatures are verified in this scheme. [2 marks]

ii. What is the standard notion of security for a digital signature scheme? Give an informal description of this security notion. [5 marks]

iii. Explain why this scheme is not secure under this security notion, by describing a specific attack against it. [2 marks]

iv. Describe how a hash function can be used to improve the security of this scheme, highlighting any properties you assume of the hash function. [2 marks]

v. Explain why this improved version of the scheme is rarely used in practice. [1 marks]

(b) In the scheme defined in item (a) above, explain why, if an attacker can factorise N, they can then efficiently recover the signing key $sk = d$. Illustrate your answer for $N = 21$ and $e = 5$. [4 marks]

(c) Consider the RSA public-key encryption scheme.

i. Define the key generation, encryption and decryption algorithms for the RSA public-key encryption algorithm. [4 marks]

ii. What is the standard notion of security for a public-key encryption scheme? Is the version of RSA you defined in item (c).i above secure under this notion? Justify your answer. [3 marks]

iii. Explain the relationship between:

A. the “integer factorisation problem” and the “RSA message recovery problem”. [2 marks]

B. the “integer factorisation problem” and the “RSA key recovery problem”. [2 marks]

Justify your answers.

iv. What is the main security parameter for the RSA algorithm? Based on this parameter, how would one typically derive the security strength (in bits) of the RSA algorithm? [2 marks]

v. Explain why RSA is often used to encrypt a symmetric key instead of being directly used to encrypt messages. [2 marks]

No further copying, distribution or publication of this exam paper is permitted.
By printing or downloading this exam paper, you are consenting to these restrictions.

(d) Do you agree with the statement ”Quantum computers pose a dire threat to the security of all public-key encryption algorithms”? Justify your answer.
[3 marks]

No further copying, distribution or publication of this exam paper is permitted.
By printing or downloading this exam paper, you are consenting to these restrictions.

Question 4

The People's Republic of Ruritania (PRR) has decided to take a great leap forward into the electronic age, by equipping its citizens with secure communications facilities.

In the planned deployment, each citizen of the PRR will be issued with a smart-card that stores a long-term Diffie-Hellman private key x and a long-term Diffie-Hellman public key $g^x \bmod p$ for that citizen. Here $p = kq + 1$ and g generates G_q, a cyclic group of prime order q in the set of integers modulo the prime p; that is, $G_q = \{g^0 = 1, g^1, g^2, \ldots, g^{q-1}\}$. All the smart-cards will use the same parameters (p, q, g).

When given another citizen's public key $g^y \bmod p$ as input, the smart-card will use its stored private key to compute and output the shared Diffie-Hellman key $K = g^{xy} \bmod p$. It is planned that this shared key will be used as the key in a symmetric encryption scheme to protect messages sent between citizens. To enable this, each citizen will be given a smart-card reader that plugs into the citizen's personal laptop or desktop computer, enabling that computer to interact with smart-cards. All encryption and decryption using the symmetric scheme will be performed using a secure messaging application that will be installed on the citizen's personal computer. That computer will also be used to send and receive messages over the Ruritanian Internet to and from other citizens of the PRR. Because all the long-term keys are stored on smart-cards, and because the people of Ruritania can all be trusted to look after their cards properly, the system's designers have decided not to bother with authentication of the public keys.

Experts at Royal Holloway have been commissioned by the Ruritanian government to perform a security analysis of the *cryptographic* aspects of the proposed system. However, they are very busy due to their heavy workload, and have decided instead to delegate the work to you. You are therefore asked to prepare an initial report that they can give to the government. **Your task is to produce that report.**

In your report, you may choose to focus on the following topics: appropriate selection of the system-wide parameters (p, q, g); the lifecycle of keys in the system; potential for attacks on the system and for system abuse; the wisdom of dispensing with authentication of public keys in the system; selection of a suitable symmetric encryption scheme; alternative cryptographic solutions. Further *cryptographic* aspects of the proposed system may be addressed in your report, and will be credited as appropriate. [34 marks]

No further copying, distribution or publication of this exam paper is permitted.
By printing or downloading this exam paper, you are consenting to these restrictions.

END

No further copying, distribution or publication of this exam paper is permitted.
By printing or downloading this exam paper, you are consenting to these restrictions.